

AI Tool Approval Checklist

Semi-hostile tools, least privilege, and the actions that must be gated

The moment an agent can *do* things — send, delete, pay, modify, execute — the risk stops being about text and starts being about actions. The governing principle: **treat every tool as semi-hostile**. Assume any tool can be driven by a poisoned prompt, and put deterministic controls between the model and the consequence. This is the Tool & API and Scoped Agency domain.

Review each tool on six axes

Inventory every tool the agent can call and answer these for each. A tool that fails on identity or approval is a finding regardless of how useful it is.

Axis	The question	Good answer
Permission	What can this tool actually do?	Narrowest scope that works
Identity	Whose credential does it act under?	The agent's own unique identity
Least privilege	Does it have more access than needed?	No; scoped down
Approval	Is a high-impact action gated?	Human-in-the-loop for consequence
Determinism	Who enforces the limit?	Code, not the model's judgment
Logging	Is every call recorded?	Yes — tool, params, result

Actions that must be behind approval

These are the actions where a single injected instruction can cause real damage. Each should require an explicit, deterministic approval step — never fire on the model's say-so alone.

Capability	Approval required because
Send communications	Email / message can exfiltrate data or impersonate at scale.
Delete / destroy	Irreversible; a prompt-driven delete is catastrophic.
Modify records	Silent data corruption; hard to detect after the fact.
Move money / commit spend	Direct financial loss.
Execute code / commands	Arbitrary impact; treat as the highest-risk capability.
Change access / privilege	Privilege escalation and persistence.

Framework mapping

Ungated or over-privileged tools map to: **OWASP LLM06 (Excessive Agency)** and **OWASP Agentic ASI02 (Tool Misuse)**; relevant **OWASP API Top 10** items (broken authorization, SSRF) where the tool is an API; **NIST AI RMF (Manage)**; **ISO/IEC 42001**; **SOC 2 CC6 (logical access)**; and **EU AI Act Art.14 (human oversight)**. The email example maps to six frameworks from one finding.

Reviewer's quick checklist

- Every tool the agent can call is inventoried.
- Each tool acts under the agent's own unique identity — no shared credentials.
- Each tool is scoped to least privilege.
- Send / delete / modify / pay / execute / access-change actions are behind approval.
- Limits are enforced deterministically in code, not by asking the model.
- Every tool call is logged (tool, parameters, result).
- Findings mapped through the crosswalk with an "assessed as of" date.

Safety. Use safe sample data only. Never use real credentials, tokens, or customer data, and never test production systems. Any dynamic probing runs only against an explicitly authorized lab or staging environment, and all results are labeled as authorized testing.